

1. AUTHENTICATION

ID	SECURITY REQUIREMENT	PRIORITY
AST-SEC-REQ-01	The system shall require authentication before accessing protected resources.	Must
AST-SEC-REQ-02	The system shall reject invalid or expired authentication tokens.	Must
AST-SEC-REQ-03	Passwords shall never be stored in plaintext.	Must
AST-SEC-REQ-04	Authentication credentials and tokens shall not be stored in application logs.	Must

2. AUTHORIZATION AND RBAC

ID	SECURITY REQUIREMENT	PRIORITY
AST-SEC-REQ-05	The system shall enforce role-based access control on the backend.	Must
AST-SEC-REQ-06	Each API endpoint shall require the appropriate permission for the requested action.	Must
AST-SEC-REQ-07	Users shall not be able to perform actions outside their assigned role permissions.	Must
AST-SEC-REQ-08	Authorization shall be enforced independently of frontend visibility or UI restrictions.	Must
AST-SEC-REQ-09	Users shall not be able to modify their own role or permissions unless explicitly authorized.	Must

3. ORGANIZATIONAL SCOPE

ID	SECURITY REQUIREMENT	PRIORITY
AST-SEC-REQ-10	Users shall access only resources within their assigned organizational scope.	Must
AST-SEC-REQ-11	Access to child organizational units shall follow the assigned parent scope.	Must
AST-SEC-REQ-12	Users shall not access resources belonging to unrelated or sibling organizations.	Must
AST-SEC-REQ-13	Organizational scope shall be enforced by the backend.	Must
AST-SEC-REQ-14	Users shall not be able to modify their own organizational scope.	Must

4. ASSET AND CUSTODY SECURITY

ID	SECURITY REQUIREMENT	PRIORITY
AST-SEC-REQ-15	Asset modifications shall be restricted to authorized roles.	Must
AST-SEC-REQ-16	Asset transfers shall be restricted to authorized users and shall require an authenticated actor.	Must
AST-SEC-REQ-17	Asset retirement shall require appropriate authorization and approval.	Must
AST-SEC-REQ-18	Custody and transfer history shall not be silently modified or deleted.	Must
AST-SEC-REQ-19	Asset retirement shall not remove the asset from historical or audit records.	Must

5. FINANCIAL AND PROCUREMENT DATA

ID	SECURITY REQUIREMENT	PRIORITY
AST-SEC-REQ-20	Access to invoices and financial data shall be restricted to authorized roles.	Must
AST-SEC-REQ-21	Asset access shall not automatically grant access to financial information.	Must
AST-SEC-REQ-22	Procurement documents shall be accessible only within the user's authorized organizational scope.	Must
AST-SEC-REQ-23	Financial and procurement access shall be enforced by the backend.	Must

6. FILE AND ATTACHMENT SECURITY

ID	SECURITY REQUIREMENT	PRIORITY
AST-SEC-REQ-24	Invoice and warranty attachments shall be stored in private storage.	Must
AST-SEC-REQ-25	File uploads shall be validated for allowed type and size.	Must
AST-SEC-REQ-26	Attachment downloads shall require authorization.	Must
AST-SEC-REQ-27	Attachment access shall use controlled or short-lived download authorization.	Must

7. AUDIT AND LOGGING

ID	SECURITY REQUIREMENT	PRIORITY
AST-SEC-REQ-28	Critical actions shall generate audit events containing the actor and timestamp.	Must
AST-SEC-REQ-29	Asset transfers, custody changes, retirement, permission changes, and security events shall be auditable.	Must
AST-SEC-REQ-30	Audit records shall be protected from unauthorized modification or deletion.	Must
AST-SEC-REQ-31	Logs shall not contain passwords, authentication tokens, or unnecessary sensitive data.	Must

8. API AND APPLICATION SECURITY

ID	SECURITY REQUIREMENT	PRIORITY
AST-SEC-REQ-32	API endpoints shall validate authentication and authorization before performing protected operations.	Must
AST-SEC-REQ-33	Resource-level authorization shall be enforced for objects such as assets, invoices, work orders, and documents.	Must
AST-SEC-REQ-34	User-controlled input shall be validated before processing.	Must
AST-SEC-REQ-35	Database queries shall use parameterized queries or equivalent protection against injection attacks.	Must
AST-SEC-REQ-36	Sensitive errors shall not expose credentials, tokens, internal database details, or other unnecessary system information.	Must

9. AI / RISK PREDICTION SECURITY

ID	SECURITY REQUIREMENT	PRIORITY
AST-SEC-REQ-37	AI predictions shall not automatically change asset or work-order state.	Must
AST-SEC-REQ-38	AI-generated maintenance recommendations shall require human confirmation before action.	Must
AST-SEC-REQ-39	AI model/version information and prediction events shall be logged.	Must
AST-SEC-REQ-40	A deterministic non-AI fallback shall remain available if the prediction service is unavailable.	Must

10. CLIENT-SIDE TOKEN STORAGE SECURITY

ID	SECURITY REQUIREMENT	PRIORITY
AST-SEC-REQ-41	Authentication tokens shall not be stored in insecure client storage. The Flutter mobile application must use flutter_secure_storage for all token storage and must not use SharedPreferences or any unencrypted local storage for tokens.	Must

11. SECURITY ACCEPTANCE CRITERIA

The security implementation shall be considered acceptable when:

- Authentication is required for all protected operations.
- Backend authorization prevents unauthorized role actions.
- Organizational scope prevents cross-organization access.
- Financial and procurement data are protected from unauthorized roles.
- Custody, transfer, and retirement history cannot be silently altered.
- Critical security and business actions are auditable.
- Protected files cannot be accessed without authorization.
- Resource-level authorization cannot be bypassed by changing resource IDs.
- AI predictions cannot automatically perform business actions.
- Security controls remain enforced even when the frontend is bypassed.